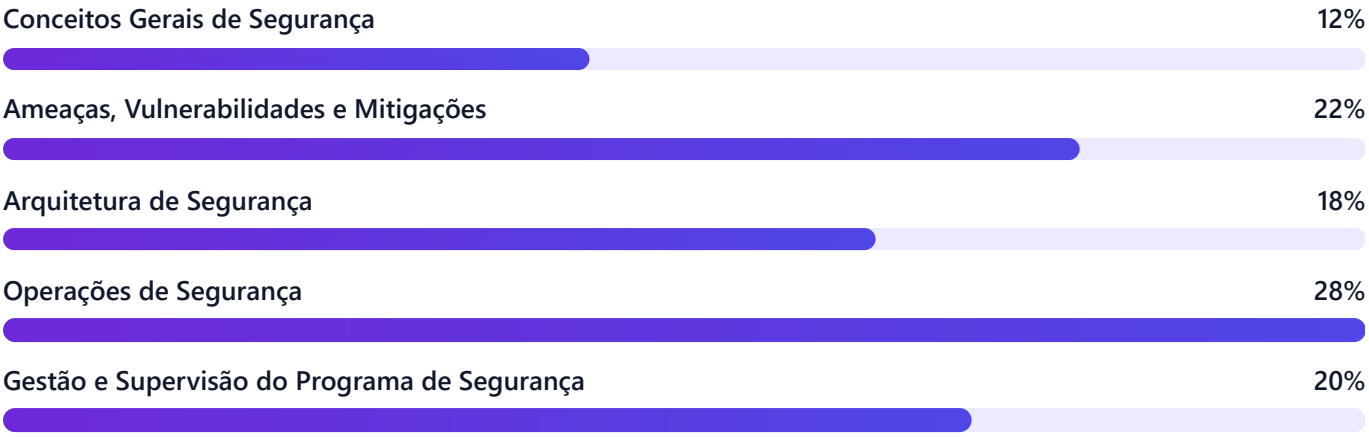
Strecht Simulados

Resumo de bolso CompTIA Security+ SY0-701

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

540	6	83%
questões no curso	provas completas	nota de corte

Como é a prova CompTIA Security+ SY0-701



Material independente de preparação, sem afiliação ou endosso de CompTIA. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame CompTIA Security+ SY0-701?

Treine com as 540 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Gestão e Supervisão do Programa de Segurança

- Cliente rescinde: impacto contratual.
- Menos erro humano: programa eficaz.
- Quanto risco aceitar: apetite.
- Tentar entrar no prédio: pentest físico.
- Termos gerais para vários serviços: MSA.
- Riscos, donos e respostas: registro de riscos.
- Recebe tudo: ambiente conhecido.
- ALE = SLE x ARO.

Ameaças, Vulnerabilidades e Mitigações

- Site frequentado pelo alvo: watering hole.
- Resposta maior que a consulta: amplificação.
- Reenviar credencial capturada: replay.
- Erro diferente por caso: enumeração de usuários.
- CPU alta e mineração: cryptojacking.
- Bloqueios estranhos e alteração indevida: indicador de ataque.
- Jailbreak: perde proteções do sistema.
- Sem atualizações do fabricante: fim de vida.

Operações de Segurança

- Automação: resposta mais rápida.
- Criada e descartada no uso: efêmera.
- Não detectou falha real: falso negativo.
- Porta 443: HTTPS.
- Uma senha para vários sistemas: SSO.
- Criar e remover contas automaticamente: automação.
- Aceitar só o formato esperado: validação de entrada.
- Falhas de login no Windows: log de segurança do SO.

Arquitetura de Segurança

- Servidor público separado: DMZ.

- Acesso administrativo intermediado: jump server.
- Voltar em minutos: hot site.
- IPS em linha: cuidado com gargalo e falha.
- Desde o último backup de qualquer tipo: incremental.
- Dispositivo furtado: criptografia de disco.
- Dois discos espelhados: RAID 1.
- Perda de região: várias regiões.

Conceitos Gerais de Segurança

- Não foi alterada: integridade.
- Blocos encadeados por hash: integridade.
- Mudança sem autorização: risco de impacto não previsto.
- Valor aleatório antes do hash: salt.
- Depois da mudança: atualizar documentação.
- Regra de firewall: técnico e preventivo.
- Atual x framework: gap analysis.
- IDS que só alerta: detectivo.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Gestão e Supervisão do Programa de Segurança

Qual documento define, de forma obrigatória e de alto nível, as regras de uso aceitável dos recursos de TI pelos funcionários?

A. Guia de boas práticas opcional
B. Procedimento de backup
C. Acordo de nível de serviço
D. Política de uso aceitável (AUP)

Questão 2 · Gestão e Supervisão do Programa de Segurança

Um funcionário nota que um colega fotografa telas com dados de clientes fora do horário. Segundo o treinamento, o que ele deve reconhecer?

A. Comportamento normal de trabalho
B. Problema de desempenho de rede
C. Falha de hardware da estação
D. Comportamento anômalo de risco

Questão 3 · Arquitetura de Segurança

A empresa testa o plano de continuidade reunindo os responsáveis numa sala para discutir, passo a passo, como reagiriam a um desastre, sem acionar sistemas. Que teste é esse?

A. Teste de penetração externo
B. Teste de failover completo
C. Simulação com troca de site
D. Exercício de mesa (tabletop)

Questão 4 · Ameaças, Vulnerabilidades e Mitigações

Um atacante explora uma falha no hipervisor para sair de uma máquina virtual e acessar outras VMs do mesmo host. Que vulnerabilidade é essa?

A. Escape de máquina virtual
B. Reutilização de recursos
C. Injeção de SQL em aplicação
D. Configuração de nuvem incorreta

Questão 5 · Operações de Segurança

Uma empresa quer que um e-mail que falhe nas verificações SPF e DKIM seja rejeitado e que o dono do domínio receba relatórios. Qual mecanismo define isso?

A. Registro PTR reverso
B. Registro TXT de verificação
C. Política DMARC do domínio
D. Registro MX secundário

Questão 6 · Gestão e Supervisão do Programa de Segurança

Novos funcionários recebem o manual de segurança e assinam um termo dizendo que leram e entenderam as políticas. Qual é o objetivo da assinatura?

A. Dispensar o monitoramento de acessos
B. Registrar o reconhecimento das políticas
C. Substituir o treinamento de segurança
D. Garantir que nunca haverá incidentes

Questão 7 · Gestão e Supervisão do Programa de Segurança

Qual papel é responsável pela guarda e pelos controles técnicos dos dados, conforme definido pelo proprietário?

A. O controlador dos dados
B. O custodiante dos dados
C. O auditor externo
D. O titular dos dados

Questão 8 · Gestão e Supervisão do Programa de Segurança

Um pentest é feito sem que a equipe de testes receba informações sobre o ambiente, como um atacante externo. Qual tipo de ambiente é esse?

A. Ambiente conhecido
B. Ambiente parcialmente conhecido
C. Ambiente desconhecido
D. Ambiente de produção simulado

Questão 9 · Ameaças, Vulnerabilidades e Mitigações

Um roteador de filial ainda usa usuário e senha de fábrica e está acessível pela Internet. Qual vulnerabilidade existe?

A. Criptografia de disco desativada
B. Firmware com assinatura válida
C. Falta de backup de configuração
D. Credenciais padrão não alteradas

Questão 10 · Ameaças, Vulnerabilidades e Mitigações

Um atacante altera a tabela ARP da rede local para receber o tráfego destinado ao gateway. Que ataque é esse?

A. Envenenamento de ARP
B. Bomba lógica agendada
C. Clonagem de crachá RFID
D. Colisão de hash MD5

Gabarito comentado

1. D) Política de uso aceitável (AUP)
Regras de uso dos recursos: AUP.

2. D) Comportamento anômalo de risco
Fotografar dados: comportamento anômalo.

3. D) Exercício de mesa (tabletop)
Discussão sem acionar sistemas: tabletop.

4. A) Escape de máquina virtual
Sair da VM para o host: VM escape.

5. C) Política DMARC do domínio
Rejeitar e receber relatórios: DMARC.

6. B) Registrar o reconhecimento das políticas
Termo assinado: reconhecimento das políticas.

7. B) O custodiante dos dados
Guarda e controles técnicos: custodiante.

8. C) Ambiente desconhecido
Sem informações: ambiente desconhecido.

9. D) Credenciais padrão não alteradas
Senha de fábrica: credencial padrão.

10. A) Envenenamento de ARP
Tabela ARP alterada: envenenamento de ARP.

Pronto para o exame CompTIA Security+ SY0-701?

Treine com as 540 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →